ĐẠI HỌC BÁCH KHOA HÀ NỘI

TRƯỜNG CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG

BÁO CÁO CÁ NHÂN

BÀI TẬP FULLSTACK – QUẢN LÝ NGƯỜI DÙNG VÀ PHÂN QUYỀN RBAC

Học phần: Công nghệ Web và Dịch vụ trực tuyến (IT4409)

Thông tin	Nội dung
Họ và tên	Lê Minh Hoàng
MSSV	20251295M
Lớp / Mã lớp học	Chưa được cung cấp; không suy đoán.
Email sinh viên	Chưa xác nhận email SIS. Email demo: 20251295m@example.test.
Nhóm BTL	Chưa được cung cấp. Các tên trong seed là giả lập.
Giảng viên	Chưa được cung cấp.
Thời điểm tạo báo cáo	20:34:50 30/10/2026

Bản local với dữ liệu giả lập

Báo cáo được AI tổng hợp từ mã nguồn, kết quả kiểm thử và ảnh chụp thực tế ở localhost theo yêu cầu người dùng. Chưa triển khai online, chưa có ảnh DevTools/Atlas/Render. Không phải bản xác nhận hoàn thành toàn bộ tiêu chí nộp bài. Mục 8 ghi dữ kiện kỹ thuật để sinh viên tự phân tích; không thay lời tự thuật hoặc câu trả lời cá nhân của sinh viên.

MỤC LỤC

Giữ cấu trúc mục 1–10 và các câu hỏi của template. Số trang dưới đây là các trang nội dung của bản PDF được tạo cùng báo cáo.

1. Thông tin nộp bài	3
2. Tổng quan kết quả	4
3. Quá trình phát triển	5
4. Kiến trúc và thiết kế đã hiện thực	6
4.3. Bản đồ endpoint → mã nguồn	7
5. Triển khai online	8
5.4. Sự cố khi triển khai	9
6. Minh họa kết quả	10
6.2. Hiển thị theo quyền	11
6.3. Quản lý người dùng	12
6.3. Quản lý người dùng – gán vai trò	13
6.4. Quản lý vai trò	14
6.5. Kỹ thuật	15
7. Kiểm thử	16
7.2. Các test chưa đạt	17
8. Phân tích và giải thích	18
8. Phân tích và giải thích – Câu 2–3	19
8. Phân tích và giải thích – Câu 4	20
8. Phân tích và giải thích – Câu 5	21
8. Phân tích và giải thích – Câu 6–8	22
8. Phân tích và giải thích – Câu 9–10	23
9. Khai báo sử dụng AI	24
10. Tự đánh giá và bài học	25

Quy ước bằng chứng: ảnh có hậu tố local là ảnh viewport Chrome headless ở localhost, không có thanh địa chỉ/DevTools. Các trang tổng hợp JSON là bản trình bày dữ liệu đo thật, không phải ảnh công cụ quản trị. Các mục online chưa thực hiện được ghi rõ thay vì dùng ảnh giả.

1. Thông tin nộp bài

1.1. Đường dẫn

Hạng mục	Địa chỉ / trạng thái
Repository	https://github.com/macLeHoang/CNWeb — chưa push: git push --dry-run xác nhận máy chưa đăng nhập GitHub.
Commit mã nguồn đối chiếu	4d194c96e47fc1a07998e3f54a0d4630cf0c282e
Frontend local	http://127.0.0.1:5500/
Backend local	http://127.0.0.1:3001/api/v1
Frontend / Backend online	Chưa triển khai. Chưa có URL backend được xác nhận.
Postman	postman/Ex3-RBAC-T01-T24.postman_collection.json
Video demo	Không thực hiện (không bắt buộc).

1.2. Tài khoản để giảng viên kiểm tra trên bản online

Bốn tài khoản dưới đây đang sử dụng trên LOCAL. Mật khẩu là mật khẩu demo công khai, phải đặt lại bằng biến môi trường riêng trước khi triển khai online.

Vai trò	Email demo	Mật khẩu demo
super-admin	gv.admin.20251295@example.test	Demo@2026
user-manager	gv.manager.20251295@example.test	Demo@2026
auditor	gv.auditor.20251295@example.test	Demo@2026
member	gv.member.20251295@example.test	Demo@2026

1.3. Môi trường

Thành phần	Phiên bản / cách chạy
Node.js	v24.12.0
Express / Mongoose	^5.1.0 / ^9.0.0; phiên bản khóa trong package-lock.json
Database	MongoDB local qua mongodb-memory-server; dữ liệu demo lưu dưới backend/.runtime/mongo
Frontend	React 18 CDN, Axios CDN, Babel; HTTP local port 5500
Backend	Express local port 3001; Render chưa được kết nối

2. Tổng quan kết quả

2.1. Bảng hoàn thành chức năng

#	Chức năng	Trạng thái
1	Đăng nhập POST /auth/tokens, GET /me	Đã kiểm tra local
2	Middleware authenticate và requirePermission	Đã kiểm tra local
3	GET /users tìm kiếm/lọc/sort/phân trang	Đã kiểm tra local
4	POST /users, allow-list, mật khẩu mạnh	Đã kiểm tra local
5	PATCH /users và khóa/mở khóa	Đã kiểm tra local
6	DELETE /users xóa mềm	Đã kiểm tra local
7	Gán/gỡ vai trò idempotent, chống leo thang	Đã kiểm tra local
8	CRUD vai trò, thay quyền, bảo vệ role	Đã kiểm tra local
9	Danh mục quyền và quyền của vai trò	Đã kiểm tra local
10	Response/mã lỗi thống nhất	Đã kiểm tra local
11	Frontend đăng nhập và interceptor	Đã kiểm tra local
12	Hiển thị theo quyền	Đã kiểm tra local
13	Trang Người dùng và các modal	Đã kiểm tra local
14	Trang Vai trò và modal	Đã kiểm tra local
15	Responsive dưới 768px	Đã kiểm tra local
16	Triển khai online	Chưa thực hiện
17	Phần mở rộng	Không làm, ngoài phạm vi đã chốt
18	Dữ liệu người thật trong seed	Giả lập theo yêu cầu; chưa đạt tiêu chí dữ liệu thật

2.2. Tóm tắt (5–8 câu)

Ứng dụng hiện có 18 endpoint REST và frontend React cho quản lý người dùng, vai trò và hồ sơ cá nhân. Quyền được hợp từ các vai trò và đọc lại trong từng request. Backend đạt 36 test tự động; Postman chạy bằng Newman đạt 37 assertion. Kiểm thử Chrome hoàn thành 11 kịch bản giao diện, gồm bốn role và màn hình mobile. Seed có 25 tài khoản với dữ liệu giả lập được gắn rõ miền example.test. Hai thí nghiệm local xác nhận vai trò bị thu hồi có hiệu lực ngay và lỗi regex khi bỏ escape. Chưa có triển khai online, thông tin lớp/giảng viên, dữ liệu sinh viên thật hoặc nhận xét cá nhân do sinh viên xác nhận.

3. Quá trình phát triển

3.1. Nhật ký thực hiện

Nhật ký dưới đây dựa trên thời điểm commit, không suy diễn số giờ làm việc. Không có dữ liệu theo dõi thời gian nên cột thời lượng ghi 'Không đo'.

Ngày	Công việc	Thời lượng	Commit
2026-10-27	Document Ex3 setup and add Postman collection	Không đo	1615fda
2026-10-28	Refresh authorization state after frontend errors	Không đo	eda0f49
2026-10-28	Record AI assistance for assignment disclosure	Không đo	54446bf
2026-10-30	Add synthetic dataset and runnable persistent local demo	Không đo	4f9de39
2026-10-30	Verify Postman and browser workflows and generate evidence-based report	Không đo	fc1ffe8
2026-10-30	Test last-admin safeguards and malformed token subjects	Không đo	9611ea7
2026-10-30	Add local evidence and 25-page RBAC report with disclosed limitations	Không đo	f3b03e9
2026-10-30	Protect last administrator against concurrent writes and add CI	Không đo	4d194c9

3.2. Lịch sử commit

```
4d194c9 2026-10-30 Protect last administrator against concurrent writes and add CI
f3b03e9 2026-10-30 Add local evidence and 25-page RBAC report with disclosed limitations
9611ea7 2026-10-30 Test last-admin safeguards and malformed token subjects
fc1ffe8 2026-10-30 Verify Postman and browser workflows and generate evidence-based report
4f9de39 2026-10-30 Add synthetic dataset and runnable persistent local demo
54446bf 2026-10-28 Record AI assistance for assignment disclosure
eda0f49 2026-10-28 Refresh authorization state after frontend errors
1615fda 2026-10-27 Document Ex3 setup and add Postman collection
fbeb7a6 2026-10-27 Build permission-aware React administration UI
f197d90 2026-10-27 Add automated RBAC contract tests
0a69f7e 2026-10-27 Add role permission APIs and deterministic seed
b5f73a4 2026-10-27 Implement user management and role assignment APIs
```

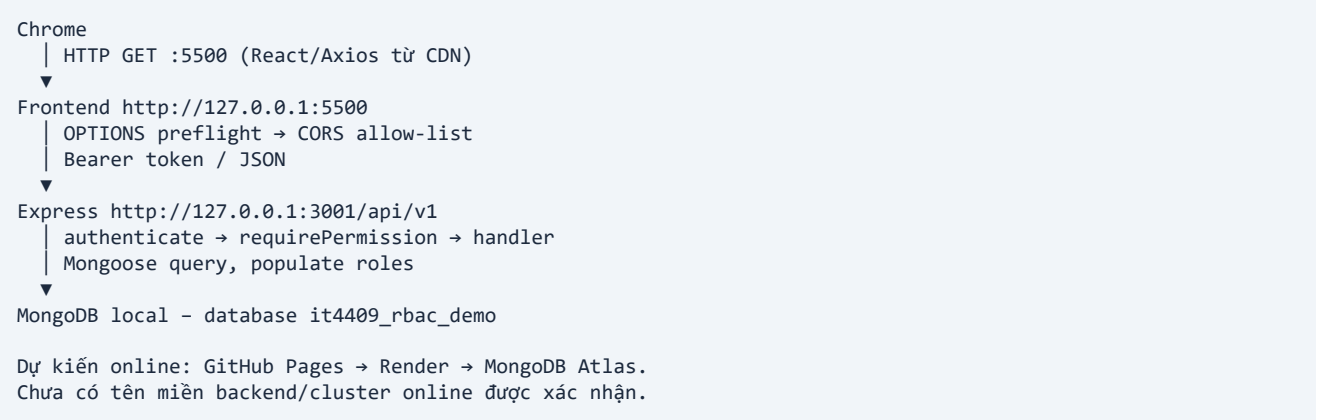
Các commit mới chưa push vì GitHub yêu cầu đăng nhập (kiểm tra dry-run đã thực hiện). Permalink trong báo cáo được tạo từ commit local và chỉ truy cập được sau khi push đúng commit lên repository. Workflow .github/workflows/ex3-rbac.yml đã chuẩn bị để tự chạy kiểm thử sau khi push; chưa có kết quả GitHub Actions online.

3.3. Cấu trúc thư mục thực tế

```
backend/
  app.js, server.js, seed.js, seed-data.js
  models/{Permission,Role,User}.js
  middleware/auth.js
  routes/{auth,users,roles,permissions}.js
  utils/{http,rbac}.js
  scripts/{demo,verify-local,experiments,record-tests,build-report}.js
  test/{api,seed}.test.js
frontend/index.html
postman/Ex3-RBAC-T01-T24.postman_collection.json
evidence/
render.yaml, README.md, AI-LOG.md
```

4. Kiến trúc và thiết kế đã hiện thực

4.1. Sơ đồ triển khai



Hình S00. Sơ đồ local mô tả cấu hình đã chạy. Sơ đồ có tên miền online thật theo template chưa thể hoàn thành trước khi deploy.

4.2. Khác biệt so với đề bài

Đặc tả	Trạng thái thực tế	Lý do
Dữ liệu thành viên thật	20 hồ sơ giả lập + 1 tài khoản sinh viên demo + 4 tài khoản kiểm tra	Người dùng yêu cầu tạo dữ liệu khi không có danh sách thật.
Atlas/online trong báo cáo	MongoDB local; chưa có deploy	Chưa có kết nối tài khoản dịch vụ.
Ảnh online với URL/DevTools	Ảnh viewport local và dữ liệu JSON	Bằng chứng local; không thay thế ảnh online theo template.
Cấu trúc backend gợi ý	Tách app.js và server.js	Cho phép Supertest nạp app không cần bind port.

4.3. Bản đồ endpoint → mã nguồn

Endpoint	Vị trí handler	Permission
POST /auth/tokens	backend/routes/auth.js:10	Công khai
GET /me	backend/routes/auth.js:32	Đã đăng nhập
GET /users	backend/routes/users.js:33	users:read
POST /users	backend/routes/users.js:56	users:create
GET /users/:userId	backend/routes/users.js:91	users:read
PATCH /users/:userId	backend/routes/users.js:93	users:update
DELETE /users/:userId	backend/routes/users.js:111	users:delete
GET /users/:userId/roles	backend/routes/users.js:119	users:read
PUT /users/:userId/roles/:roleId	backend/routes/users.js:124	roles:assign
DELETE /users/:userId/roles/:roleId	backend/routes/users.js:131	roles:assign
GET /roles	backend/routes/roles.js:37	roles:read
POST /roles	backend/routes/roles.js:53	roles:create
GET /roles/:roleId	backend/routes/roles.js:66	roles:read
PATCH /roles/:roleId	backend/routes/roles.js:69	roles:update
DELETE /roles/:roleId	backend/routes/roles.js:78	roles:delete
GET /roles/:roleId/permissions	backend/routes/roles.js:85	roles:read
PUT /roles/:roleId/permissions	backend/routes/roles.js:90	roles:update
GET /permissions	backend/routes/permissions.js:9	permissions:read

Commit tham chiếu: 4d194c96e47fc1a07998e3f54a0d4630cf0c282e. Mọi vị trí trên được tính tự động từ source, không phải số dòng ước lượng.

backend/middleware/auth.js:5 — https://github.com/macLeHoang/CNWeb/blob/4d194c96e47fc1a07998e3f54a0d4630cf0c282e/Ex3-20251295M-LeMinhHoang/backend/middleware/auth.js#L5

backend/routes/users.js:124 — https://github.com/macLeHoang/CNWeb/blob/4d194c96e47fc1a07998e3f54a0d4630cf0c282e/Ex3-20251295M-LeMinhHoang/backend/routes/users.js#L124

5. Triển khai online

5.1. Lựa chọn nền tảng

Kiến trúc đã chọn: GitHub Pages cho frontend tĩnh, Render cho backend Node và MongoDB Atlas cho CSDL. Chưa tạo tài nguyên hoặc đo giới hạn gói host trong phiên này. File render.yaml và các lệnh build/start đã được chuẩn bị. Không tuyên bố đã deploy khi chưa có URL hoặc trạng thái trả về từ dịch vụ.

5.2. Biến môi trường trên host

Tên biến	Mục đích	Local / host
MONGODB_URI	Chuỗi kết nối MongoDB	Demo dùng MongoDB local; host cần Atlas URI riêng
JWT_SECRET	Ký/kiểm tra JWT	Demo sinh ngẫu nhiên mỗi lần chạy; host lưu secret riêng
ACCESS_TOKEN_TTL	Thời hạn access token	3600 giây trong cấu hình mẫu
CORS_ORIGINS	Danh sách origin được đọc response	Local cho localhost/127.0.0.1; host cho origin Pages
PORT	Port HTTP server	Local 3001; host cung cấp
NODE_ENV	Môi trường runtime	production trên Render

5.3. Các bước triển khai

Các bước đã thực hiện: cài npm dependencies; khởi động demo MongoDB/Express/frontend; chạy test; tạo render.yaml. Các bước chưa thực hiện: kết nối GitHub/Render/Atlas, tạo database user và IP access list, cấu hình secret trên host, push commit, deploy và đổi API_BASE. Đây là kế hoạch còn lại, không phải nhật ký deploy đã thành công.

Hình S01. Chưa có ảnh dashboard Render vì chưa deploy. Hình S02. Chưa có ảnh Atlas vì chưa có cluster online. Không tạo ảnh thay thế giả.

5.4. Sự cố khi triển khai

Chưa triển khai lên host nên không có sự cố 'local chạy được nhưng online lỗi' để báo cáo. Khó khăn thực tế của môi trường phát triển là kết nối npm/CDN trong sandbox và lượt browser test đầu tiên bị timeout trước khi React render. Sau khi chạy kiểm thử với quyền truy cập mạng phù hợp, Chrome tải thư viện và hoàn thành các kịch bản. Đây là sự cố local, không được tính là sự cố triển khai theo template.

5.5. Số liệu đo trên bản online

Chưa có số đo online. Bảng dưới là số đo LOCAL qua Node fetch, không phải DevTools. Không đo cold start trên Render và chưa đo số OPTIONS thực từ browser Network.

Request	Status	Thời gian (ms)	Body (byte)	Thời điểm UTC
/users?page=1&limit=10	200	10.5	3410	2026-10-29T17:16:00.756Z
/users?page=1&limit=100	200	10.59	8419	2026-10-29T17:16:00.767Z

limit=100 trả nhiều bản ghi hơn limit=10; số byte tăng theo dữ liệu trong demo. Mỗi phép đo chỉ có một mẫu, không đủ để kết luận hiệu năng production. Cần đo lại online với Disable cache, nhiều mẫu và cùng điều kiện.

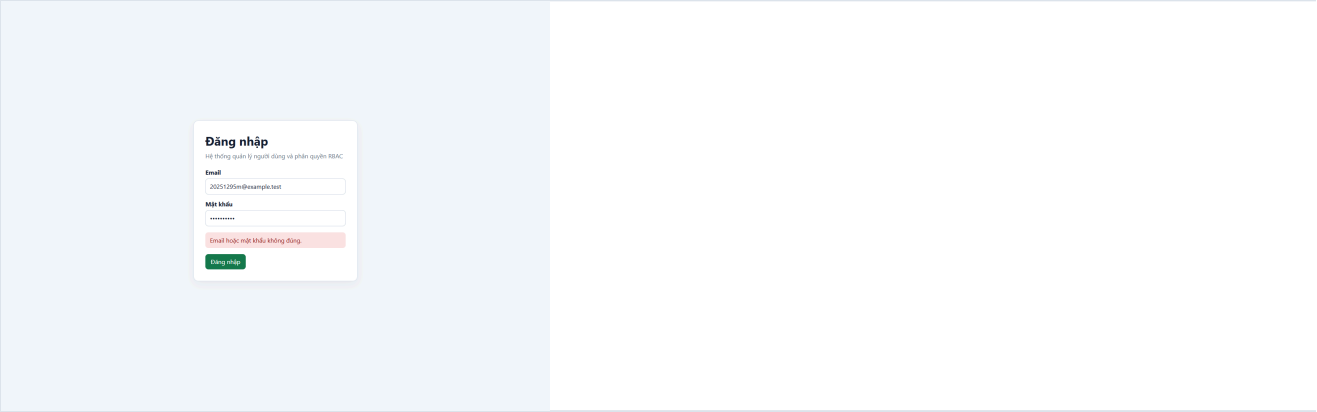

```
{
  "status": 204,
  "headers": {
    "access-control-allow-headers": "Authorization,Content-Type",
    "access-control-allow-methods": "GET,POST,PUT,PATCH,DELETE",
    "access-control-allow-origin": "http://127.0.0.1:5500",
    "access-control-expose-headers": "Location"
  }
}
```


File nguồn: evidence/network-results.json. Token trong bằng chứng đã rút gọn; không ghi JWT_SECRET hay URI riêng.

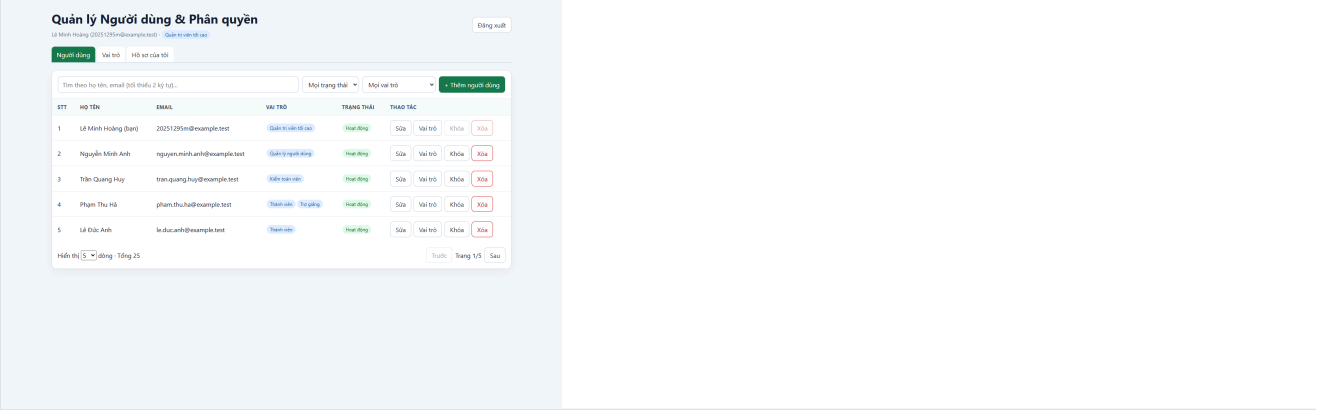
6. Minh họa kết quả

6.1. Xác thực

Tất cả ảnh dưới là viewport Chrome headless ở http://127.0.0.1:5500, chụp tự động. Chưa đáp ứng yêu cầu thanh địa chỉ và DevTools của ảnh online trong template.

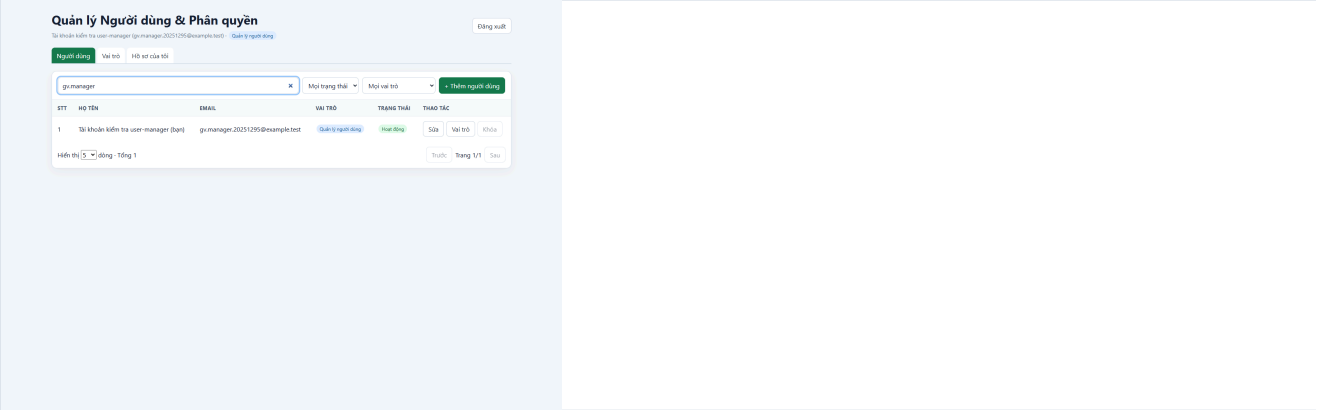


Hình S03 (local). Sai mật khẩu hiển thị thông điệp từ server; mã 401 được xác nhận bằng test/API, không hiển thị DevTools trong ảnh.

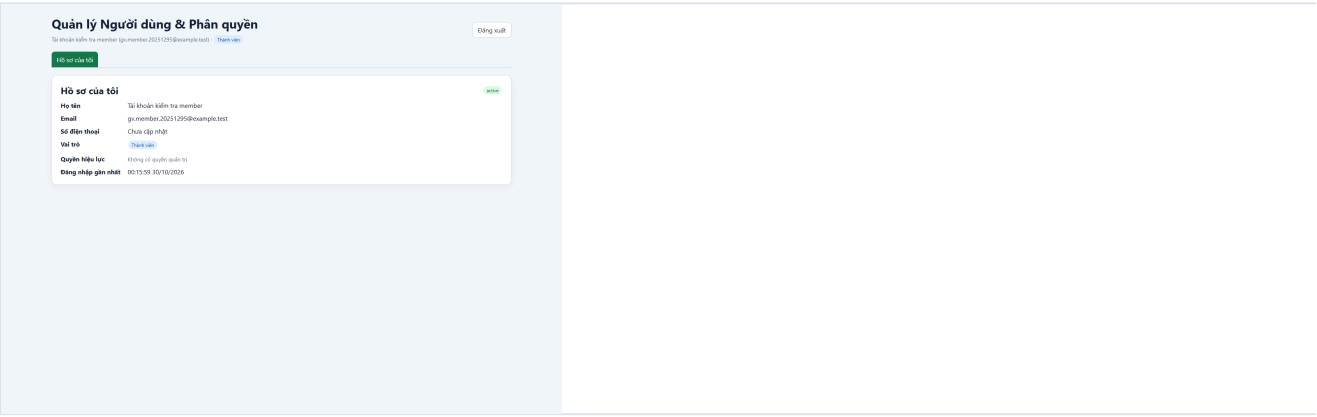


Hình S04 (local). Header có Lê Minh Hoàng và tài khoản demo; super-admin thấy ba tab và thao tác quản trị.

6.2. Hiển thị theo quyền



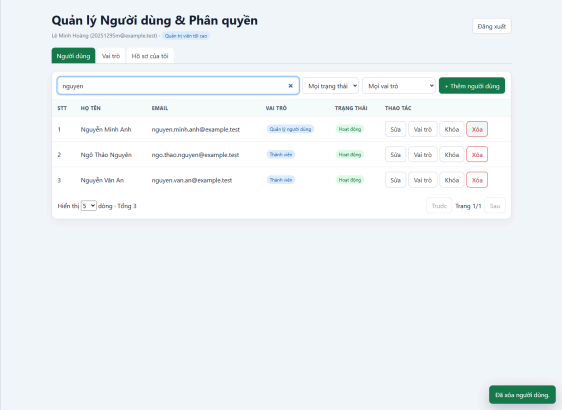
Hình S05 (local). User-manager không thấy nút Xóa; tìm dòng bản thân để kiểm tra Khóa bị vô hiệu.



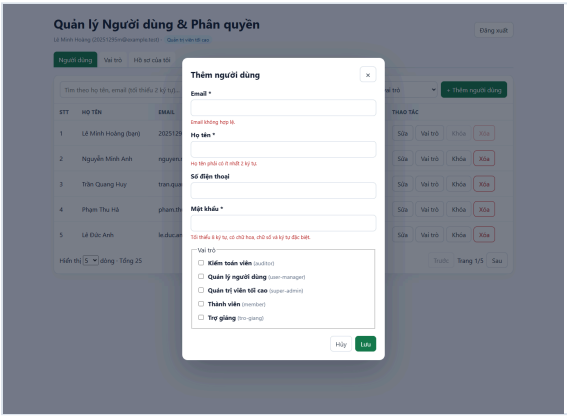
Hình S06 (local). Member chỉ thấy tab Hồ sơ của tôi; quyền quản trị trống.

Ngoài ảnh, kiểm thử trình duyệt xác nhận auditor không thấy nút tạo/xóa hoặc tab vai trò. Chi tiết: evidence/ui-results.json (11 kịch bản đạt, 0 lỗi JavaScript trang).

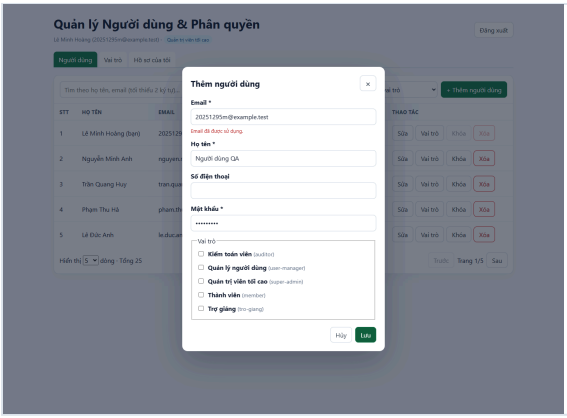
6.3. Quản lý người dùng



Hình S07 (local). Tìm từ khóa nguyen trên backend, hiển thị phân trang và các hồ sơ giả lập khớp.

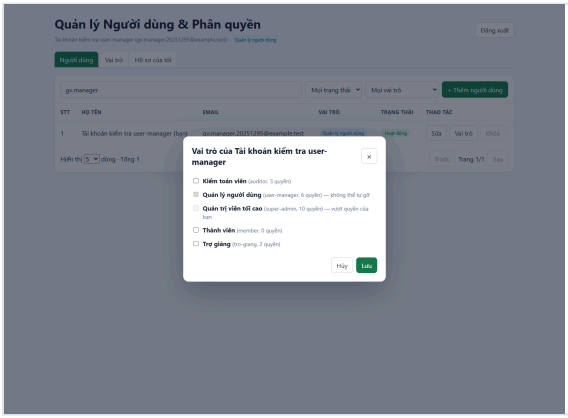


Hình S08a (local). Modal thêm người dùng hiển thị validation cho các ô chưa hợp lệ.



Hình S08b (local). Lỗi EMAIL_ALREADY_EXISTS được gắn dưới ô Email.

6.3. Quản lý người dùng – gán vai trò



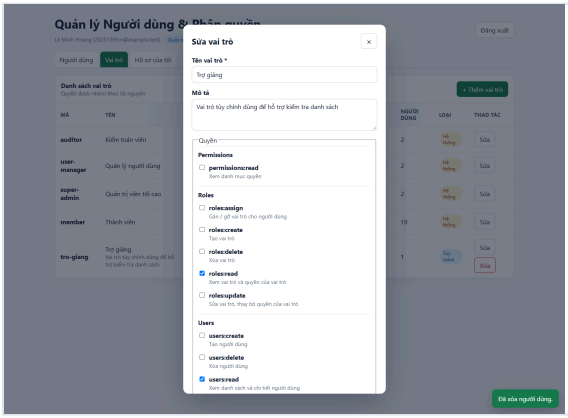
Hình S09 (local). Checkbox vượt quyền bị khóa và vai trò hiện có của bản thân không thể tự gỡ.

Kiểm thử UI đã tạo user tạm, sửa số điện thoại, khóa, mở khóa và xóa mềm. Dữ liệu tạm được xóa mềm sau kịch bản. Postman T13 xác nhận hai lần PUT trả 204 và role auditor chỉ có một lần trong response GET vai trò.

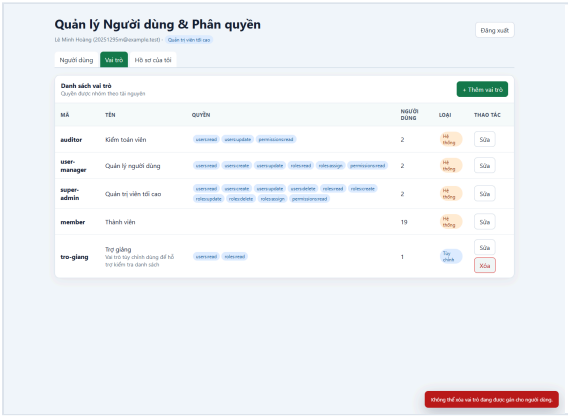
frontend/index.html:839 — https://github.com/macLeHoang/CNWeb/blob/4d194c96e47fc1a07998e3f54a0d4630cf0c282e/Ex3-20251295M-LeMinhHoang/frontend/index.html#L839

backend/routes/users.js:127 — https://github.com/macLeHoang/CNWeb/blob/4d194c96e47fc1a07998e3f54a0d4630cf0c282e/Ex3-20251295M-LeMinhHoang/backend/routes/users.js#L127

6.4. Quản lý vai trò



Hình S10 (local). Vai trò tùy chỉnh tro-giang và checkbox quyền được nhóm theo resource.



Hình S11 (local). UI báo lỗi khi xóa vai trò đang được sử dụng; Postman T21 xác nhận 409 ROLE_IN_USE.

Kiểm thử UI bổ sung đã tạo custom role, sửa tên, thay bộ quyền và xóa role không sử dụng thành công.

6.5. Kỹ thuật

Hình S12. Chưa có ảnh DevTools Network/preflight online. Bằng chứng local thay thế để tham khảo nằm trong network-results.json, status OPTIONS = 204.

Hình S13. Authorization đã được interceptor gắn; ví dụ đã che: Bearer eyJhbGciOi… [redacted]. Chưa có ảnh DevTools header online.



Hình S14 (local). Viewport 390×844; test xác nhận trang không tràn ngang và bảng cuộn trong vùng chứa.

frontend/index.html:407 — https://github.com/macLeHoang/CNWeb/blob/4d194c96e47fc1a07998e3f54a0d4630cf0c282e/Ex3-20251295M-LeMinhHoang/frontend/index.html#L407

7. Kiểm thử

7.1. Kết quả Postman T01–T24 trên bản online

Chưa chạy online. Kết quả LOCAL từ Newman: 37 request, 37 assertion, 0 lỗi. Thời điểm UTC: 2026-10-29T17:15:51.167Z. T13, T15 và T17 có nhiều request vì phải kiểm tra trạng thái sau thao tác. Mỗi request đều có assertion status.

Case	Kết quả LOCAL	Đạt?
T01 GET /users không token	401 UNAUTHENTICATED	Có
T02 member GET /users	403 FORBIDDEN	Có
T03 phân trang và sort	200	Có
T04 tìm kiếm và lọc	200	Có
T05 limit không hợp lệ	400 INVALID_QUERY_PARAMETER / OUT_OF_RANGE	Có
T06 tạo người dùng	201	Có
T07 email trùng	409 EMAIL_ALREADY_EXISTS	Có
T08 mật khẩu yếu	400 VALIDATION_ERROR / WEAK_PASSWORD	Có
T09 tạo user vượt quyền	403 PRIVILEGE_ESCALATION	Có
T10 PATCH một phần	200	Có
T11 PATCH roles bị chặn	400 VALIDATION_ERROR / FIELD_NOT_ALLOWED	Có
T12 tự khóa	403 SELF_ACTION_FORBIDDEN	Có
T13 gán auditor lần 1	204	Có
T13 gán auditor lần 2	204	Có
T13 kiểm tra không trùng role	200	Có
T14 gán super-admin vượt quyền	403 PRIVILEGE_ESCALATION	Có
T15 super-admin gỡ manager	204	Có
T15 token cũ mất quyền ngay	403 FORBIDDEN	Có
T15 khôi phục role trước T16	204	Có
T16 manager không được xóa	403 FORBIDDEN	Có
T17 super-admin xóa mềm	204	Có
T17 GET user đã xóa	404 USER_NOT_FOUND	Có
T17 đăng nhập user đã xóa	401 INVALID_CREDENTIALS	Có
T18 ObjectId sai	404 USER_NOT_FOUND	Có
T19 mã role trùng	409 ROLE_CODE_EXISTS	Có
T20 sửa quyền role hệ thống	409 SYSTEM_ROLE_PROTECTED	Có
T21 xóa role đang dùng	409 ROLE_IN_USE	Có
T22 quyền không tồn tại	400 PERMISSION_NOT_FOUND / NOT_FOUND	Có
T23 header role giả	403 FORBIDDEN	Có
T24 JSON hỏng	400 MALFORMED_JSON	Có

Hình S15. Chưa có ảnh Postman Collection Runner online; bằng chứng máy đọc được là evidence/postman-results.json, thu từ Newman chạy collection gốc.

7.2. Các test chưa đạt

Backend tự động: 36 test đạt, 0 lỗi. Postman local: đạt toàn bộ 37 assertion. Browser local: đạt 11 kịch bản, không có page error. Các test chéo với mock server của giảng viên chưa chạy do chưa có URL mock. Toàn bộ kiểm tra online còn chờ deploy.

7.3. Kiểm thử bảo mật thủ công

Kịch bản được thực thi tự động trong page.evaluate của Chrome với tài khoản member, tương đương gọi fetch từ trang nhưng không phải ảnh Console thao tác tay. Backend từ chối tạo user dù request trực tiếp bỏ qua nút giao diện.


```
{
  "status": 403,
  "body": {
    "error": {
      "code": "FORBIDDEN",
      "message": "Bạn không có quyền thực hiện thao tác này (cần: users:create)."
    }
  }
}
```


Hình S16. Chưa có ảnh Console online. File member-console-result.json chứa response thực của lệnh fetch local.

Kịch bản UI đã đạt
Sai mật khẩu hiển thị lỗi 401
Super-admin có đầy đủ tab và dòng của bản thân đầu tiên
Validation tại ô nhập và lỗi email trùng từ backend
Tạo/sửa/khóa/mở khóa/xóa người dùng và tải lại danh sách
Vai trò tùy chỉnh, checkbox quyền và lỗi ROLE_IN_USE
Tạo/sửa tên/thay quyền/xóa vai trò bằng giao diện
User-manager không có nút xóa; vai trò vượt quyền bị vô hiệu
Auditor thấy người dùng nhưng không có tạo, xóa hoặc tab vai trò
Member chỉ có Hồ sơ; gọi fetch POST trực tiếp bị backend chặn 403
Mobile 390px: bảng cuộn bên trong, trang không tràn ngang
Xóa token rồi gọi API quay về đăng nhập

8. Phân tích và giải thích

Phần này giữ các câu hỏi của template, kèm bằng chứng kỹ thuật do AI tổng hợp. Sinh viên cần tự viết lời giải, đánh giá cá nhân và xác nhận hiểu biết trước khi nộp. Không coi các ghi chú dưới đây là câu trả lời tự thuật đã được sinh viên xác nhận.

Câu 1. Lần theo một request qua mã nguồn của bạn

Đăng nhập bằng user-manager và gán vai trò auditor cho một người dùng (bằng giao diện hoặc Postman). Liệt kê theo đúng thứ tự những hàm/middleware trong mã nguồn của bạn mà request PUT /users/:userId/roles/:roleId đi qua, từ lúc vào server tới lúc trả response:

Tạm thêm một dòng console.log in ra req.permissions ngay trước khi kiểm tra quyền, gọi lại request, chụp log (local hoặc log trên host), rồi xóa dòng log đó.

Log hiển thị nội dung req.permissions của user-manager.

Nếu thay auditor bằng super-admin, request dừng ở bước nào trong bảng trên, trả về mã gì, vì sao?

Dữ kiện để sinh viên tự trả lời

Thứ tự	Thành phần	Vai trò
1	CORS / express.json	Kiểm tra browser origin và parse JSON
2	authenticate	JWT.verify; tìm user active; populate roles; hợp permission
3	requirePermission("roles:assign")	Thiếu quyền trả 403 FORBIDDEN
4	serializeRbacWrite	Chờ lượt ghi trong cùng tiến trình Node; giữ khóa đến khi xử lý xong
5	loadUser → loadRole	Nạp lại tài nguyên sau khi lấy khóa; tài nguyên thiếu trả 404
6	missingPermissions	Role vượt quyền trả 403 PRIVILEGE_ESCALATION
7	User.updateOne $addToSet	Thêm idempotent; trả 204 không body; giải phóng khóa trong finally


```
{
  "request": "PUT /users/:userId/roles/:roleId",
  "permissions": [
    "permissions:read",
    "roles:assign",
    "roles:read",
    "users:create",
    "users:read",
    "users:update"
  ],
  "status": 204,
  "observation": "Temporary wrapper around actual authenticate; production file not edited"
}
```


Hình S17. Log được thu trong wrapper tạm của middleware authenticate trên database thử nghiệm riêng; chưa có ảnh console log. Gán auditor trả 204; nếu gán super-admin bằng manager, kiểm tra missingPermissions chặn trước updateOne.

backend/routes/users.js:124 — https://github.com/macLeHoang/CNWeb/blob/4d194c96e47fc1a07998e3f54a0d4630cf0c282e/Ex3-20251295M-LeMinhHoang/backend/routes/users.js#L124

8. Phân tích và giải thích – Câu 2–3

Câu 2. Thí nghiệm "phá" code

Chọn một trong hai thí nghiệm, làm trên máy local, ghi kết quả rồi khôi phục code:

(a) Tạm xóa requirePermission("users:delete") khỏi route DELETE /users/:userId, dùng token user-manager xóa một người dùng.

(b) Tạm bỏ hàm thoát ký tự đặc biệt khi đưa q vào $regex, gọi GET /users?q=(((.

Kết quả request khi code bị "phá" và sau khi khôi phục.

Bạn đã sửa dòng nào (file:dòng)? Kết quả quan sát được là gì? Trong hệ thống thật, lỗ hổng này gây hậu quả gì? Có test case nào ở mục 7 phát hiện được lỗi này không?

Kết quả thí nghiệm thực tế


```
{
  "query": "q=(((",
  "changedExpression": "$regex: escapeRegex(keyword) -> $regex: keyword",
  "brokenStatus": 500,
  "actualError": "Regular expression is invalid: missing closing parenthesis",
  "restoredStatus": 200,
  "sourceUnchanged": true
}
```


Hình S18. Dữ liệu local từ bản route được compile trong bộ nhớ với biểu thức escape bị bỏ; route gốc trên đĩa không sửa. Đây là biến thể của thí nghiệm (b), khác quy trình sửa file rồi khôi phục trong template. T04 dùng từ khóa bình thường không phát hiện lỗi này; cần regression query chứa ký tự regex.

backend/routes/users.js:46 — https://github.com/macLeHoang/CNWeb/blob/4d194c96e47fc1a07998e3f54a0d4630cf0c282e/Ex3-20251295M-LeMinhHoang/backend/routes/users.js#L46

Câu 3. Đoạn mã khó nhất bạn đã viết

Dán đoạn mã (≤ 20 dòng) mà bạn mất nhiều thời gian nhất, kèm permalink.

(1) Giải thích từng dòng hoặc từng khối bằng lời của bạn. (2) Phiên bản đầu tiên bạn viết sai ở đâu, bạn phát hiện ra bằng cách nào? (3) Commit sửa là commit nào?

Chưa có dữ kiện để khẳng định đoạn nào khó nhất với cá nhân sinh viên hoặc phiên bản đầu sinh viên viết sai ở đâu. Mã dưới là ví dụ tham khảo đã có trong sản phẩm; phần trải nghiệm cá nhân phải do sinh viên xác nhận.

```
  const before = new Set(req.role.permissions);
  const after = new Set(checked.permissions);
  const changed = [...new Set([...before, ...after])].filter((code) => before.has(code) !== after.has(code));
  const missing = missingPermissions(changed, req.permissions);
  if (missing.length) return fail(res, 403, "PRIVILEGE_ESCALATION", `Bạn không thể thay đổi các quyền mình
không có: ${missing.join(", ")}.`);
  req.role.permissions = checked.permissions;
  await req.role.save();
  return res.json(roleView(req.role, await countUsers(req.role._id)));
});
```

backend/routes/roles.js:96 — https://github.com/macLeHoang/CNWeb/blob/4d194c96e47fc1a07998e3f54a0d4630cf0c282e/Ex3-20251295M-LeMinhHoang/backend/routes/roles.js#L96

8. Phân tích và giải thích – Câu 4

Câu 4. 401 hay 403 trong code của bạn

Liệt kê mọi vị trí trong Backend của bạn trả 401 và trả 403 (file:dòng, mã error.code). Chọn một cặp tình huống dễ nhầm, giải thích vì sao bạn chọn mã đó. Frontend của bạn xử lý 401 và 403 khác nhau thế nào (file:dòng)?

Vị trí	HTTP	error.code
backend/middleware/auth.js:7	401	UNAUTHENTICATED
backend/middleware/auth.js:13	401	TOKEN_EXPIRED
backend/middleware/auth.js:14	401	INVALID_TOKEN
backend/middleware/auth.js:17	401	INVALID_TOKEN
backend/middleware/auth.js:19	401	INVALID_TOKEN
backend/middleware/auth.js:28	403	FORBIDDEN
backend/routes/auth.js:21	401	INVALID_CREDENTIALS
backend/routes/auth.js:22	403	ACCOUNT_LOCKED
backend/routes/users.js:69	403	FORBIDDEN
backend/routes/users.js:73	403	PRIVILEGE_ESCALATION
backend/routes/users.js:98	403	SELF_ACTION_FORBIDDEN
backend/routes/users.js:112	403	SELF_ACTION_FORBIDDEN
backend/routes/users.js:126	403	PRIVILEGE_ESCALATION
backend/routes/users.js:132	403	SELF_ACTION_FORBIDDEN
backend/routes/users.js:134	403	PRIVILEGE_ESCALATION
backend/routes/roles.js:60	403	PRIVILEGE_ESCALATION
backend/routes/roles.js:100	403	PRIVILEGE_ESCALATION

Frontend 401 xóa token và phát auth:expired; 403 phát auth:forbidden để tải lại /me. Nguồn: frontend/index.html:436. Sinh viên tự chọn cặp tình huống dễ nhầm và giải thích.

8. Phân tích và giải thích – Câu 5

Câu 5. Thu hồi quyền có hiệu lực ngay

Trên bản online: mở hai trình duyệt (hoặc một cửa sổ ẩn danh). Cửa sổ A đăng nhập user-manager, cửa sổ B đăng nhập super-admin. B gỡ vai trò user-manager của A. A thao tác tiếp mà không đăng nhập lại.

Hai cửa sổ cạnh nhau: B vừa gỡ vai trò, A nhận lỗi ở thao tác kế tiếp (thấy mã lỗi trong Network).

Dòng code nào trong Backend của bạn khiến điều này xảy ra (file:dòng)? Nếu bạn lưu danh sách quyền trong JWT, kết quả thí nghiệm sẽ khác thế nào? Giao diện của A phản ứng ra sao sau lỗi đó (có tải lại /me không)?


```
{
  "tokenReused": true,
  "before": 200,
  "deleteRole": 204,
  "after": 403,
  "code": "FORBIDDEN"
}
```


Hình S19. Chưa có ảnh hai cửa sổ online. Thí nghiệm API local dùng cùng access token trước/sau: GET 200 → gỡ role 204 → GET 403. Quyền không chứa trong JWT; authenticate đọc lại database. Nếu nhúng và tin quyền cũ trong token thì việc thu hồi sẽ bị trì hoãn đến lúc token hết hạn hoặc có cơ chế vô hiệu hóa bổ sung.

backend/middleware/auth.js:18 — https://github.com/macLeHoang/CNWeb/blob/4d194c96e47fc1a07998e3f54a0d4630cf0c282e/Ex3-20251295M-LeMinhHoang/backend/middleware/auth.js#L18

8. Phân tích và giải thích – Câu 6–8

Câu 6. Một lỗi thật bạn đã gặp và sửa

Chọn lỗi khó nhất trong quá trình làm bài (không trùng với sự cố ở mục 5.4).

Triệu chứng (thông báo lỗi nguyên văn hoặc ảnh)

Các giả thuyết bạn đã thử, theo thứ tự

Công cụ dùng để chẩn đoán

Nguyên nhân gốc

Commit sửa (hash + permalink)

Điều bạn rút ra

Lỗi source thực được phát hiện ở seed.js trước lần sửa hiện tại: xóa ba collection trước khi gọi required cho các mật khẩu. Nếu cấu hình thiếu, seed có thể thất bại sau khi dữ liệu cũ đã bị xóa. Bản sửa xây dựng/validate toàn bộ users trước khi connect hoặc delete, và yêu cầu --reset khi database đã có user. Không tái hiện xóa dữ liệu thật; test seed xác nhận thiếu mật khẩu bị chặn ở bước buildUsers. Sinh viên cần tự xác định đây có phải lỗi khó nhất của mình hay không.

backend/seed.js:55 — https://github.com/macLeHoang/CNWeb/blob/4d194c96e47fc1a07998e3f54a0d4630cf0c282e/Ex3-20251295M-LeMinhHoang/backend/seed.js#L55

Câu 7. Một quyết định thiết kế của bạn

Chọn một quyết định bạn đã cân nhắc giữa các phương án, ví dụ: lưu token ở sessionStorage hay localStorage; Frontend phục vụ chung với Backend hay tách riêng; gán vai trò bằng nhiều request song song hay tuần tự; phân trang offset hay cursor; lưu roles trong User hay dùng collection trung gian.

Các phương án bạn cân nhắc; phương án bạn chọn và chỗ thể hiện trong code (file:dòng); đánh đổi (bạn được gì, mất gì); trong tình huống nào bạn sẽ đổi sang phương án khác.

Dữ kiện thiết kế: token lưu sessionStorage theo đặc tả; request interceptor đọc storage trước mỗi request. Lợi ích: phiên kết thúc khi đóng tab; hạn chế: script có XSS vẫn có thể đọc token. Không chuyển sang cookie httpOnly vì đề yêu cầu Bearer header và frontend CDN; triển khai cookie sẽ cần xem lại contract CORS/CSRF và tích hợp mock. Đây là phân tích kỹ thuật để sinh viên tự diễn đạt quyết định.

Câu 8. CORS trên bản triển khai của bạn

(1) Origin thật của Frontend là gì? Cấu hình CORS của Backend trên host đang cho phép những origin nào (dán giá trị CORS_ORIGINS, đây không phải bí mật)? (2) Dán nguyên văn các header Access-Control-* trong response preflight bạn chụp ở ảnh S12 và giải thích từng header. (3) Thử gọi API của bạn từ Console của một trang web khác (ví dụ https://example.com): kết quả là gì, vì sao, và vì sao Postman lại gọi được bình thường?

Origin local thực: http://127.0.0.1:5500. Backend demo cho phép localhost:5500 và 127.0.0.1:5500. CORS_ORIGINS trên host chưa được cấu hình. Header local đo được:

```
{
  "access-control-allow-headers": "Authorization,Content-Type",
  "access-control-allow-methods": "GET,POST,PUT,PATCH,DELETE",
  "access-control-allow-origin": "http://127.0.0.1:5500",
  "access-control-expose-headers": "Location"
}
```

Allow-Origin giới hạn origin được browser đọc; Allow-Methods liệt kê method cho preflight; Allow-Headers cho phép Authorization và Content-Type; Expose-Headers cho phép JS đọc Location. Chưa chạy thí nghiệm trên Console một trang bên ngoài. Postman không thực thi cơ chế CORS của browser, vì vậy CORS không thay thế authenticate/requirePermission.

8. Phân tích và giải thích – Câu 9–10

Câu 9. Mở rộng yêu cầu (không cần viết code)

Giả sử có yêu cầu mới: "Mỗi khoa có quản lý riêng; quản lý khoa chỉ được xem, sửa, gán vai trò cho người dùng thuộc khoa mình."

Trong mã nguồn hiện tại của bạn, những file/hàm nào phải sửa, sửa thế nào (mô tả)? Cần thêm trường dữ liệu, endpoint hoặc permission nào? Quy tắc chống leo thang đặc quyền cần thay đổi gì? Có rủi ro bảo mật mới nào?

Ghi chú thiết kế, chưa implement: thêm departmentId vào User và dữ liệu ngữ cảnh quản lý; không lấy phạm vi khoa từ client để quyết định quyền. Tạo middleware kiểm tra scope sau authenticate, áp bộ lọc departmentId cho GET /users và kiểm tra target ở PATCH/gán role. Cần tránh IDOR khi gọi userId thuộc khoa khác, tránh gán role quản trị toàn hệ thống thông qua manager khoa và không cho tự sửa departmentId để vượt phạm vi. Test phải có hai khoa, cùng permission nhưng khác phạm vi. Sinh viên tự quyết định endpoint/permission mới và giải thích trên mô hình của mình.

Câu 10. Hạn chế và hướng cải thiện

Nêu ít nhất 3 hạn chế cụ thể của sản phẩm hiện tại (chức năng, bảo mật, hiệu năng, trải nghiệm), mỗi hạn chế kèm cách bạn sẽ khắc phục nếu có thêm một tuần.

Hạn chế cụ thể	Hướng cải thiện nếu có thêm thời gian
Chưa online; demo chạy local và cần mạng cho CDN	Kết nối tài khoản dịch vụ, deploy, kiểm tra CORS/HTTPS và chụp lại ảnh đúng template
Không có refresh/revoke token server	Thiết kế refresh token quay vòng và logout server; nằm ngoài phần bắt buộc đã chốt
Khóa ghi RBAC mới chỉ bảo vệ trong một tiến trình Node	Nếu chạy nhiều instance, chuyển sang khóa dùng chung/giao dịch ở database; test đồng thời một tiến trình hiện đã đạt
Seed dùng hồ sơ giả lập	Đổi sang dữ liệu được xác minh/được phép sử dụng; giữ miền test cho QA
Danh sách role UI tải tối đa 100 role	Phân trang hoặc tải mọi trang role để không thiếu khi dữ liệu lớn
Dev tooling có dependency cũ từ Newman	Rà npm audit và tách runner khỏi production; production cài --omit=dev

9. Khai báo sử dụng AI

Công cụ: OpenAI Codex. AI đã đọc yêu cầu, đề xuất kiến trúc, tạo/chỉnh sửa phần đáng kể mã nguồn backend/frontend, tạo test, dữ liệu giả lập, script thu bằng chứng và báo cáo này. Không khai báo là chỉ hỏi lỗi/cú pháp. Sinh viên chưa xác nhận đã tự hiểu và kiểm tra toàn bộ nội dung.

Giai đoạn	Nội dung hỗ trợ	Kiểm chứng
Đọc đề và lập plan	18 endpoint, RBAC, FE, test, deploy, hồ sơ	Đối chiếu PDF và template
Triển khai lần đầu	Models, auth, routes, React, seed, Postman	Test backend và JSX
Theo yêu cầu dữ liệu giả lập	20 hồ sơ giả lập, demo local bền vững	Test seed, chạy demo thực
Thu bằng chứng	Newman, Chrome UI, network, thí nghiệm	36 backend test; 37 assertion; 11 UI case
Báo cáo	Tổng hợp facts, source refs, ảnh và giới hạn	Kèm JSON nguồn và script tái tạo

Gợi ý/test chưa phù hợp đã được sửa: test T04 cũ chỉ duyệt dữ liệu trả về nên có thể pass với mảng rỗng. Bản mới yêu cầu có kết quả và từng user khớp keyword; T13 được bổ sung GET kiểm tra không trùng; T15 khôi phục manager trước T16 để T16 kiểm tra đúng thiếu quyền delete của manager. Browser selector ban đầu tìm exact 'Trợ giảng' không khớp vì cell gồm mô tả; sửa chọn cell code tro-giang. Chi tiết còn lại ghi trong AI-LOG.md.

Quy định trong tài liệu giới hạn việc dùng AI viết thay toàn bộ mã/câu trả lời mục 8. Mức hỗ trợ thực tế của bản này vượt việc hỏi lỗi hoặc cú pháp; cần trao đổi với giảng viên và tự hoàn thiện theo quy định học phần trước khi dùng làm bài nộp.

10. Tự đánh giá và bài học

10.1. Tự chấm theo thang điểm của đề

Tiêu chí	Điểm tối đa	Tự chấm	Căn cứ hiện có
Xác thực	1.0	Chưa tự chấm	Backend và UI local đã kiểm tra
Người dùng	2.0	Chưa tự chấm	CRUD, tìm/lọc/phân trang trong test
RBAC Backend	2.0	Chưa tự chấm	T01–T24 và experiments.json
Vai trò	1.0	Chưa tự chấm	Test API và CRUD role UI
Chuẩn API	1.0	Chưa tự chấm	HTTP/error contract tests
Frontend	2.0	Chưa tự chấm	Bốn role, mobile, interceptor
Postman, dữ liệu, vấn đáp	1.0	Chưa tự chấm	Postman local đạt; dữ liệu giả lập; chưa vấn đáp
Cộng điểm	+1.0	Không xác nhận	Chưa deploy và không làm phần mở rộng

Không tự ghi điểm tổng khi thiếu xác nhận hiểu biết của sinh viên, kiểm thử mock, hồ sơ online và tiêu chí dữ liệu thật. Các test local đạt không đồng nghĩa bài đạt điểm tối đa.

10.2. Bài học

Các quan sát kỹ thuật có bằng chứng: (1) permission bị gỡ làm token cũ trả 403 ngay vì middleware đọc DB; (2) query có ký tự regex gây 500 nếu bỏ escape, nhưng 200 với source gốc; (3) UI ẩn nút vẫn cần backend chặn fetch trực tiếp. Đây là dữ kiện để sinh viên viết ba bài học cá nhân và điều sẽ làm khác nếu bắt đầu lại; chưa tự nhận các trải nghiệm này thay cho sinh viên.

Cam kết

Bản báo cáo có hỗ trợ AI và dữ liệu giả lập đã được khai báo. Chưa thay sinh viên ký hoặc xác nhận lời cam kết cá nhân. Lê Minh Hoàng cần đọc lại, sửa phần phân tích bằng lời của mình, bổ sung thông tin còn thiếu và ký sau khi kiểm chứng.

Ngày tạo bản kỹ thuật: 20:34:50 30/10/2026. Người được ghi tên: Lê Minh Hoàng, MSSV 20251295M. Chữ ký: chưa xác nhận.